

Disk Identity and Integrity

Pushkar Chitnis

(Azure Confidential Computing)

Scenario

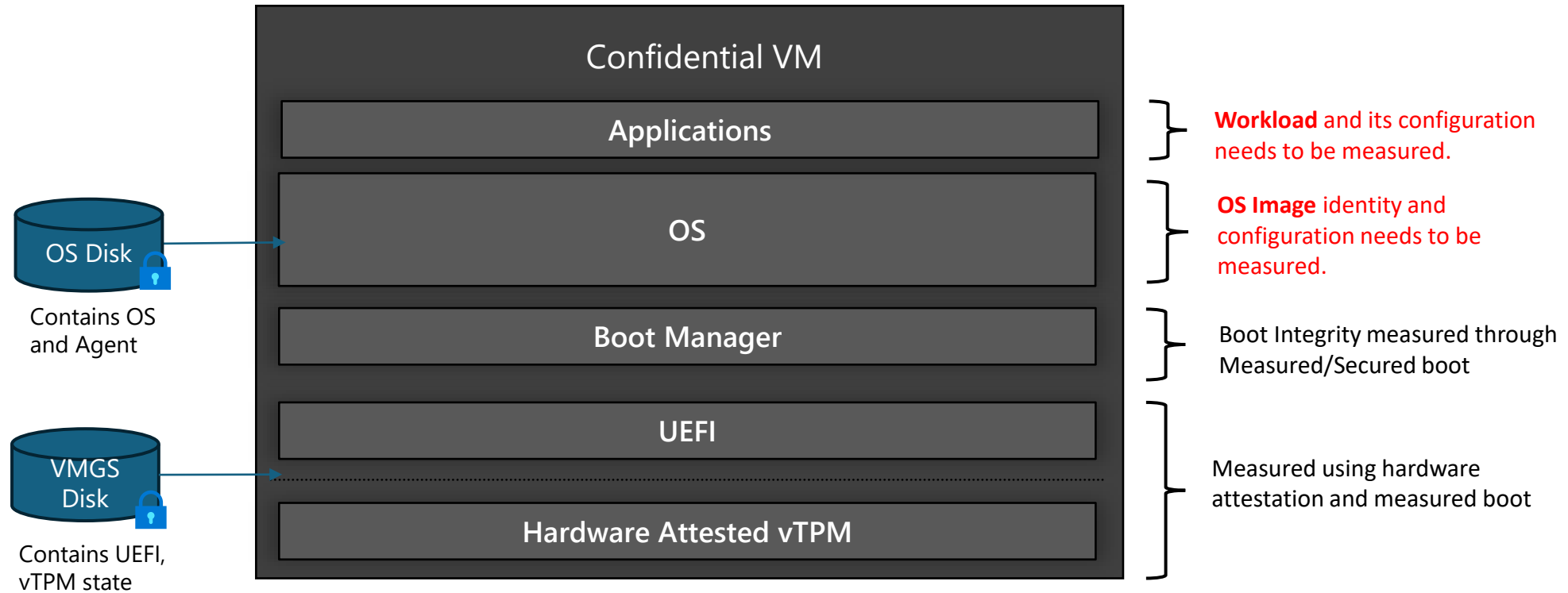
Disk state and configuration are part of effective Confidential Trust Boundary of a Confidential VM.

- To reason about security state of a Virtual Machine, we need to reason about security state of its disks.
 - Who published the OS image used to boot the VM?
 - Can we establish a cryptographic identity for an OS Disk?
 - Can we assert this identity, if disk's ReadWrite state is persisted across reboots?
 - Can we generalize above primitives to any disks attached to VM?

We are interested in identifying collaborators / partners interested in this problem space.

Confidential VM Stack

TCB Components and properties which need to be captured in attestation

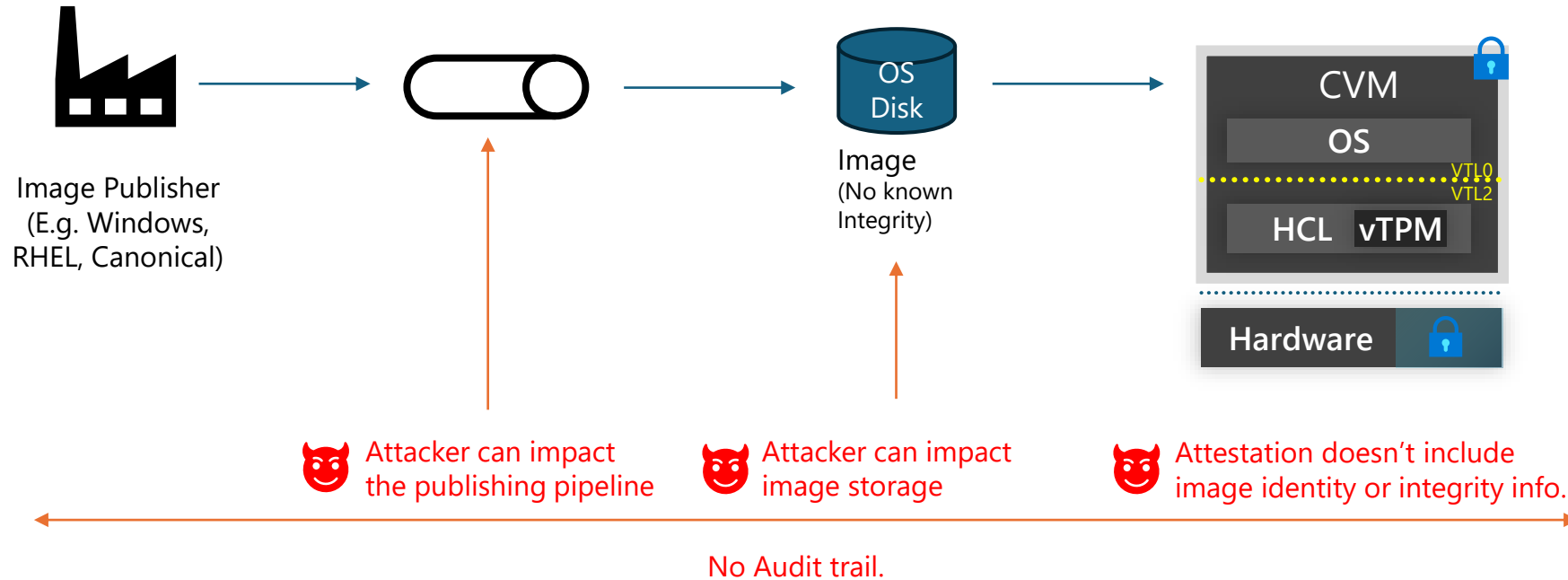


Azure vTPM attestation and binding:

https://github.com/CCC-Attestation/meetings/blob/main/materials/MikeStunes_vTPM_Attestation.pdf

OS Disk Integrity

OS disk integrity is critical to reason about confidential VM security posture

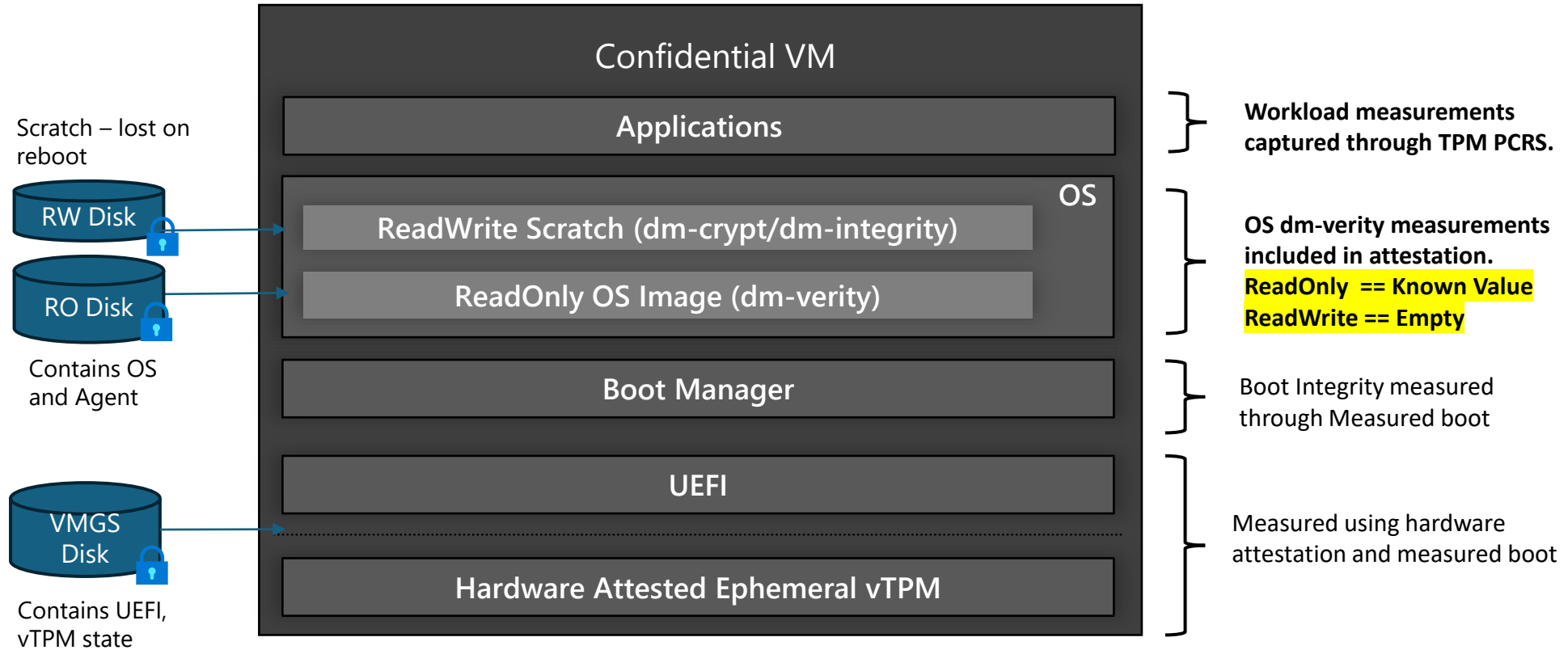


Integrity means that all state transitions of the OS disk are authorized

- The disk starts from a **known initial state**, and
- **Every subsequent modification** to that disk is **caused only by software executing inside the Conf. VM**.
- No external entity (host or control plane) can modify, replace, or roll back disk state **without detection**.

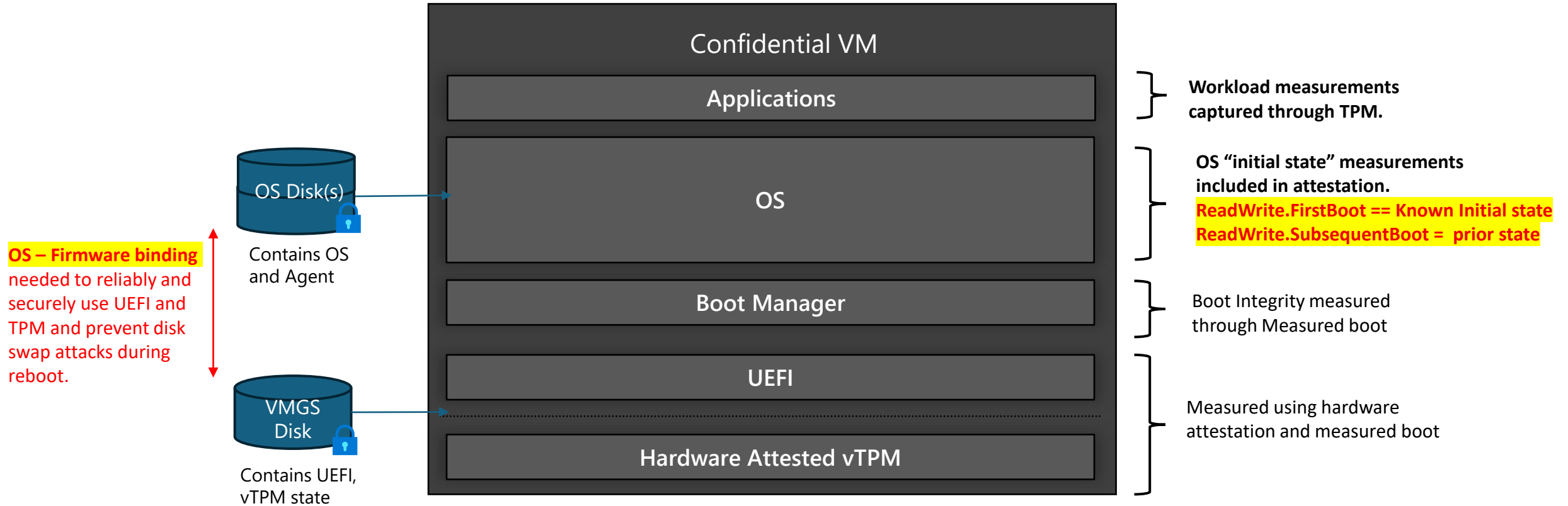
Confidential VM – Purely Ephemeral

In purely ephemeral configuration, all state is reset to known good integrity state across reboots.



Confidential VM – Persisted

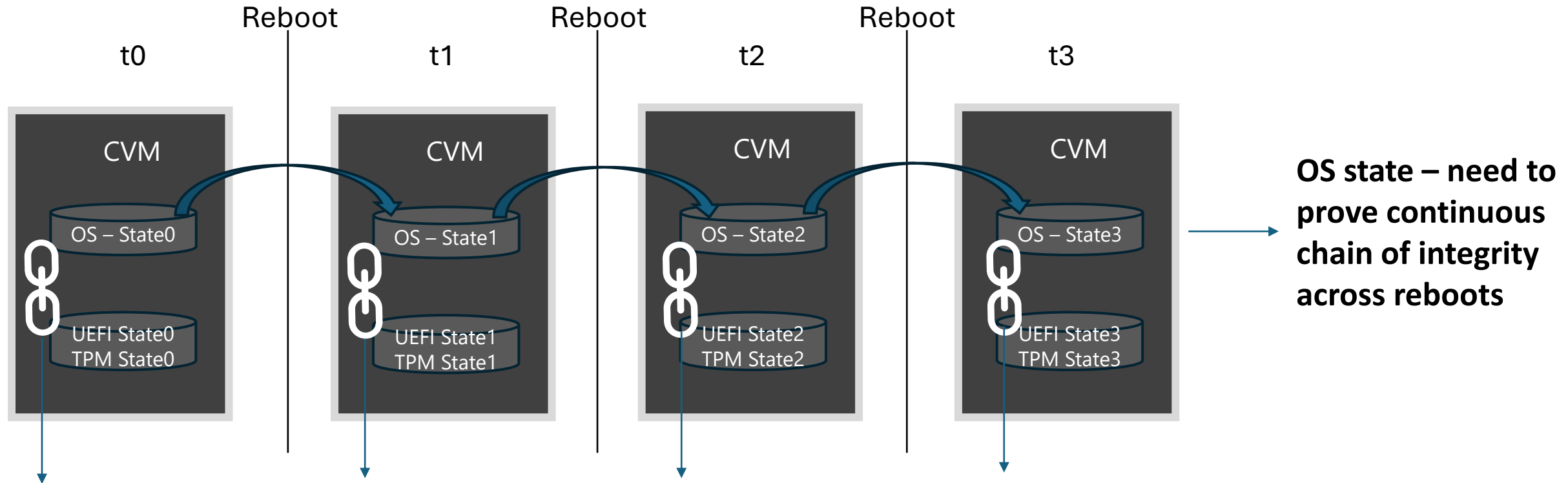
In persisted configuration, all state is retained across reboots.



Note: There is no re-initialization across reboots.

Confidential VM – Persisted state

In persisted configuration, all OS state is retained across reboots.



OS state – Firmware state need cryptographic binding to enable reliable and secure use of TPM and prevent state swap or state rollback attacks.

Any rollbacks or replays, if allowed, are for the entire OS state/firmware state collective.

OS Disk Identity and Integrity

Verify OS disk identity and Integrity and attest at boot and reboot

- OS Disk Identity
 - “Who published the image?”
 - Identity includes Initial OS Image hash, attributes and signer.
- Runtime time Integrity
 - Protect against external disk tampering during runtime.
 - Maintain continuous ordered integrity chain thru lifetime of CVM
- Attestation: Attest OS Disk Identity through boot and reboot.
 - Attestation should guarantee that OS disk was provisioned using specified Image.
- Bind: Ensure firmware/vTPM state and OS state are bound to each other.